INTENDENCIA DE SAN JOSÉ

PORTAL VIAL

CIBERSEGURIDAD

Registro consolidado de hallazgos y controles

Portal Vial IMSJ - documentación consistente, clara y trazable

Registro consolidado de hallazgos y controles

Proyecto: Educación Vial IMSJ - Portal Vial. **Corte documental:** 21/10/2026.

1. Fuentes y alcance

Fuente	Alcance y referencia
Semgrep 1.180.0	JSON posterior y salida de terminal.
ZAP 2.17.0	Baseline de `http://host.docker.internal:8000`; JSON y terminal.
Nmap 7.98	Registro de 8000/tcp, 21/10/2026 a las 13:03 UTC.
Auditoría Bash	Resultado final, 21/10/2026 a las 14:42:08 UTC.
Integración HTTP/MySQL	192 comprobaciones, 21/10/2026 a las 14:47:36 UTC.

El registro separa los avisos de las herramientas del análisis de su contexto y de los resultados de pruebas. Las severidades WARNING y ERROR pertenecen al formato de Semgrep; el riesgo de ZAP utiliza su escala propia.

2. Análisis estático

El JSON de Semgrep contiene seis resultados y un diagnóstico de análisis parcial.

ID	Aviso registrado	Ubicación del informe	Análisis del código consultado
HS-01	tainted-filename; WARNING	core/Auth.php:62	El contador genera el nombre mediante SHA-256 de operación e IP, agrega `.json` y lo ubica bajo CACHE_ROOT. La entrada no se utiliza como URL ni como nombre de ruta directo.
HS-02	unlink-use; WARNING	models/Archivo.php:80	La eliminación descarta URL remotas, resuelve las rutas con realpath y exige que el archivo permanezca bajo UPLOAD_ROOT antes de llamar a unlink.
HS-03	exec-use; ERROR	scripts/verificar.php:23	El rango señalado corresponde a proc*open con un arreglo de argumentos: PHP*BINARY, -l y la ruta de un PHP encontrado bajo backend. El archivo exige ejecución CLI. El análisis considera ese origen de argumentos y las condiciones de acceso al script.
HS-04	django-no-csrf-token; WARNING	Login.html:33	Regla de plantillas Django aplicada al formulario de ingreso ciudadano de una aplicación PHP/JavaScript.
HS-05	django-no-csrf-token; WARNING	Login.html:48	Misma regla aplicada al registro ciudadano.
HS-06	django-no-csrf-token; WARNING	Login.html:71	Misma regla aplicada al ingreso administrativo.
HS-07	PartialParsing; diagnóstico	Dockerfile:5-18	El analizador informa una lectura parcial del archivo; la evaluación de contenedores se complementa con Compose, salud y auditoría HTTP.

Fuentes del análisis: Auth, Archivo, verificador CLI, formularios, cliente de acceso y Dockerfile.

En HS-03, exec-use identifica la regla de la herramienta. La ubicación del aviso coincide con la llamada proc_open del verificador. Los hashes de integración identifican ese archivo; la revisión del contexto contempla argumentos separados, ejecución CLI y acceso de escritura al árbol de código.

Control de revisión SAST	Referencia
JSON con los seis avisos	semgrep-post.json.
Fuente actual identificada por hashes	integracion-final.json.

Control de revisión SAST	Referencia
Tratamiento propuesto de HS-03	Conservar el verificador CLI con argumentos separados; restringir escritura del código y revisar el aviso al modificar la ejecución de procesos. No se declara corregido ni falso positivo por decisión humana.

3. Análisis dinámico

El JSON de ZAP registra la generación del informe el 21/10/2026 a las 13:03:26, versión 2.17.0. Su campo de fecha no incluye zona horaria.

ID	Tipo de alerta	Riesgo de ZAP	Instancias	Contexto de evaluación
HD-01	Ausencia de token anti-CSRF	Medio, código 2	3	Formularios de la pantalla de acceso. El cliente JavaScript envía JSON y usa Bearer explícito para las operaciones autenticadas.
HD-02	Comentarios sospechosos	Informativo, código 0	2	Detección pasiva de texto en las respuestas.
HD-03	Aplicación web moderna	Informativo, código 0	1	Identificación de una interfaz con comportamiento JavaScript.
HD-04	Contenido no almacenable	Informativo, código 0	5	Respuestas con instrucciones de caché observadas por el análisis.
HD-05	Contenido almacenable en caché	Informativo, código 0	1	Recurso que puede conservar el navegador según sus cabeceras.

El resumen de terminal registra **0 FAIL, 4 WARN y 63 PASS**. Esos contadores son categorías del baseline; el JSON organiza sus resultados por tipo de alerta e instancia.

La configuración de Apache establece `no-store` para HTML y permite caché de una hora para recursos estáticos. La respuesta de API establece las cabeceras de sus respuestas. La auditoría Bash comprueba CSP, nosniff, anti-clickjacking y ausencia de caché en API.

La alerta CSRF se interpreta según la forma real de enviar credenciales y las operaciones públicas de login, registro y consultas. La coincidencia con una regla de Django o la existencia de un Bearer se analizan junto con ese flujo. El baseline público conserva su propio alcance, distinto de una exploración autenticada del panel.

4. Exposición y contenedores

Nmap registra Apache HTTP abierto en 8000/tcp en el objetivo local utilizado para la prueba. Compose permite definir la dirección y el puerto mediante `APP_BIND` y `APP_PORT`, y mantiene MySQL sin puerto publicado en el host.

Control	Configuración o prueba
Cuenta de aplicación	www-data.
Cuenta de base	mysql.
Sistema de archivos raíz	Solo lectura en ambos servicios.
Escalamiento de privilegios	no-new-privileges en ambos servicios.
Capacidades	Se descartan todas; app agrega NET*BIND*SERVICE.
Escritura	Volúmenes persistentes y temporales tmpfs declarados.
Separación de publicación	Raíz PHP en public; alias de frontends de solo lectura.
Rutas privadas	La auditoría rechaza .env, config.php, SQL y recorrido fuera de storage con 404.

5. Controles revalidados mediante API

Grupo	Evidencia concreta
Sesiones	Token válido, inválido, revocado y vencido; ocultamiento de contraseña y hashes.
Roles	PERSONAL_IMSJ recibe 403 al intentar aprobar una FAQ pendiente.
Propiedad	Una cuenta no puede cancelar una reserva ajena; respuesta 404.
Archivos	Un PHP presentado como PDF se rechaza con 422.
Entradas	JSON mal formado 400; entradas SQLi/XSS controladas 422 y sin reflejo del payload XSS.
CORS	Preflight permitido 204; origen ajeno 403 y sin autorización CORS.
Métodos y rutas	Método no admitido 405; ruta inexistente 404 en los casos evaluados.
Rate limit	La secuencia de acceso controlada alcanza 429.
Transacciones	La integración provoca un fallo de auditoría y comprueba rollback del material y limpieza del PDF nuevo.

La ejecución API final registra 43 aprobadas sin fallos ni omisiones. La integración registra OK para sus 192 comprobaciones. Los controles ejecutados se conservan junto a los avisos automáticos y a las condiciones institucionales del checklist.

6. Reflexión ética

Las pruebas documentadas apuntan al entorno local del proyecto. La suite de integración exige una base aislada y utiliza registros sintéticos. La auditoría distingue operaciones de lectura y opciones de escritura, y su resultado identifica los escenarios ejecutados y omitidos.

Los registros que se comparten deben conservar fecha, alcance, versión y resultado, evitando publicar secretos o datos de personas reales. La revisión de una alerta debe atender a la ruta de datos y a la posibilidad de reproducirla. El texto del análisis conserva los contadores originales para que otra persona pueda contrastarlos.

Los controles de la aplicación y los procedimientos del organismo se complementan: dominio HTTPS, retención, contacto y operación posterior deben definirse antes de publicar el sistema.

7. Referencias

Informe SAST, informe DAST, auditoría Bash, hardening, plan e informe de pruebas, respuesta a incidentes y reflexión ética.